

Pentest Report

Resume Engine Unified

March 25, 2026

Pentest Report

Project: Resume Engine Unified

Assessment Type: Scoped local application pentest

Date: March 25, 2026

Executive Summary

A scoped pentest was conducted against the local Resume Engine application with focus on authentication, token handling, request validation, upload behavior, CORS, and backend hardening. Three meaningful security issues were identified and remediated during the engagement: missing auth throttling, JWT storage in localStorage, and missing basic security headers with Express fingerprint leakage.

Scope

In scope:

- Backend: D:\Resume Engine Unified\apps\backend
- Frontend: D:\Resume Engine Unified\apps\frontend
- Authentication and session handling
- Input validation, uploads, CORS, and API behavior

Out of scope:

- External infrastructure
- Dependency CVE inventory
- Browser exploit chain development

Methodology

Methods used:

- Static review of backend and frontend code paths
- Safe local API probing against http://localhost:3000
- Repeated invalid-auth request testing
- Response/header inspection
- Backend log review for hidden causes of generic failures

Findings

1. High - Missing auth throttling enabled brute-force attempts

Evidence: repeated invalid logins originally returned only 401 responses. After remediation the same probe returned [401,401,401,401,401,401,401,429,429].

Status: Fixed

2. High - JWT stored in localStorage

Evidence: frontend auth previously used localStorage.getItem('authToken') and localStorage.setItem('authToken', ...).

Status: Fixed by moving auth to HttpOnly cookie-backed flow and /api/auth/me restoration.

3. Medium - Missing security headers and Express fingerprinting

Evidence: /health previously exposed X-Powered-By and the app did not set baseline hardening headers.

Status: Fixed by disabling x-powered-by and adding response hardening headers.

4. Medium - Auth validation existed but was not enforced on routes

Evidence: Joi auth validators existed but auth routes originally bypassed validateBody(...).

Status: Fixed

5. Informational - CORS not openly permissive after hardening

Evidence: Origin http://evil.example did not receive Access-Control-Allow-Origin.

6. Informational - Gemini quota exhaustion affects Gemini-only features

Evidence: backend logs showed 429 Too Many Requests with quotaValue "20" for gemini-3-flash.

Evidence

Probe evidence:

- Auth throttling verification: [401,401,401,401,401,401,401,401,429,429]
- Header fingerprint evidence: X-Powered-By observed on /health before remediation
- Gemini quota evidence: 429 Too Many Requests, quotaValue "20", model gemini-3-flash

Key files reviewed:

- D:\Resume Engine Unified\apps\backend\src\App.js
- D:\Resume Engine Unified\apps\backend\src\routes\auth.routes.js
- D:\Resume Engine Unified\apps\backend\src\controllers\auth.controller.js
- D:\Resume Engine Unified\apps\backend\src\middleware\auth.middleware.js
- D:\Resume Engine Unified\apps\frontend\src\api\axios.js
- D:\Resume Engine Unified\apps\frontend\src\context\AuthContext.jsx

Remediation Status

Fixed:

- Auth throttling
- Frontend token storage in localStorage
- Basic security headers
- Express fingerprint disclosure
- Auth route validation enforcement

Residual considerations:

- Gemini quota exhaustion can still affect Gemini-only features
- CSRF protection has not yet been added for cookie-backed auth

Conclusion

The highest-value issues found during the scoped pentest were remediated successfully. The application is now materially better protected against brute-force attacks, bearer-token theft through client-side storage, and trivial framework/header disclosure.

Recommended next steps:

1. Add CSRF protection for state-changing authenticated routes.
2. Consider helmet for broader standardized header coverage.
3. Run a dedicated dependency vulnerability scan.
4. Add quota-aware UX for Gemini-backed features.